



LIDUTEC+

Gestão Industrial

Documento Técnico da Aplicação

Material para apresentação ao departamento de Tecnologia da Informação e início do processo de integração, homologação, segurança e sustentação corporativa.

Classificação: Uso interno

Versão do documento: 1.0

Data de referência: 27 de julho de 2026

Aplicação: LIDUTEC+ v0.2

Este documento não contém senhas, tokens privados ou chaves de serviço. Informações sensíveis devem ser tratadas em cofre corporativo.

Sumário executivo

O LIDUTEC+ é uma aplicação web industrial destinada à gestão de produtos, fichas técnicas, revisões, aprovações, controle de processo, produção de moldes, paradas, reclamações de clientes, cadastros mestres e acessos. A solução foi construída com frontend estático em HTML, CSS e JavaScript e utiliza o Supabase como plataforma de backend.

O objetivo deste documento é fornecer ao TI uma visão verificável da solução atual e orientar as decisões necessárias para colocá-la sob governança corporativa. A aplicação já possui autenticação, autorização por perfis e permissões, políticas de segurança no banco, migrations versionadas e fluxos transacionais. Ainda devem ser formalizados, com participação do TI, hospedagem definitiva, ambientes, domínio, SMTP, SSO, observabilidade, backup, processo de mudanças e integrações com sistemas corporativos.

Estado atual: protótipo funcional integrado a um projeto Supabase remoto, com módulos operacionais em evolução e migrations aplicadas até a versão 202607270017 .

Objetivos de negócio

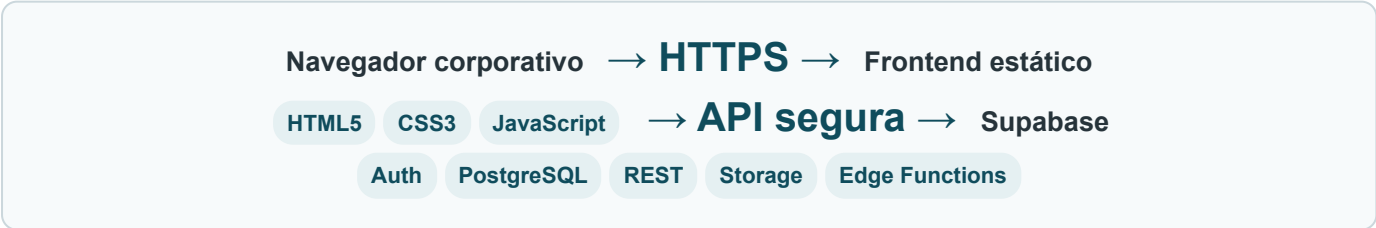
- Centralizar informações técnicas e operacionais hoje dispersas.
- Controlar versões e aprovações de fichas técnicas sem sobrescrever histórico.
- Disponibilizar dados consistentes para Engenharia, Produção e Qualidade.
- Registrar rastreabilidade de revisões, importações, decisões e usuários.
- Reduzir retrabalho por uso de documentação desatualizada.

1. Escopo funcional atual

Módulo	Capacidades principais	Situação
Autenticação e contas	Login, solicitação de acesso corporativo, confirmação de e-mail, recuperação e redefinição de senha.	Implementado
Usuários e acessos	Solicitações pendentes, ativação, perfis, permissões individuais e matriz de permissões.	Implementado
Clientes	Cadastro, pesquisa, situação, logotipo por URL, documentos, contato, endereço e observações.	Implementado
Produtos	Lista mestra, cadastro, edição, cliente, família, características e módulos técnicos.	Implementado
Fichas técnicas	Moldagem e Fusão/Vazamento, parâmetros tipados, rascunho, impressão e PDF.	Implementado
Revisões	Nova revisão baseada na anterior, histórico, vigência e destaque visual de campos alterados.	Implementado
Aprovações	Envio, decisão de Engenharia e Produção, aprovação/reprovação e datas de decisão.	Implementado
Importação de PDF	Upload, extração assistida, conferência, validação, auditoria e criação de revisão.	Implementado
Controle de processo	Consultas, lançamentos, registros e gráficos de acompanhamento de CE.	Implementado
Produção de moldes	Lançamentos, registros, paradas, categorias, indicadores e gráficos.	Implementado
Reclamações	Ocorrência, anexos, comentários, ações, prazos, responsáveis e status.	Implementado

Outras áreas citadas no modelo conceitual — como Macharia, Acabamento, Laboratório e Qualidade — possuem espaço previsto na arquitetura, mas nem todas contam com telas especializadas completas nesta versão.

2. Arquitetura da solução



2.1 Frontend

- Aplicação multipágina, sem framework de frontend e sem etapa obrigatória de compilação.
- Arquivos servidos estaticamente a partir de `pages/` e `assets/`.

- Biblioteca Supabase JS v2 carregada pelo CDN `cdn.jsdelivr.net` .
- Configuração do endpoint e chave pública de frontend em `assets/js/config.js` .
- Servidor local de desenvolvimento via Node.js: `node dev-server.cjs` .

2.2 Backend Supabase

- PostgreSQL como base transacional e fonte central dos dados.
- Supabase Auth para identidade e sessões.
- PostgREST para operações de leitura e escrita autorizadas.
- RPCs PostgreSQL para operações críticas e transacionais.
- Supabase Storage para PDFs de fichas e evidências de reclamações.
- Edge Function `gestao-usuarios` para operações administrativas que exigem privilégios elevados.

2.3 Dependências externas observadas

Dependência	Finalidade	Ação recomendada ao TI
Supabase Cloud	Autenticação, banco, APIs, storage e funções.	Aprovar fornecedor, região, contrato, retenção, SLA e responsáveis.
jsDelivr CDN	Entrega da biblioteca <code>@supabase/supabase-js@2</code> .	Liberar domínio no proxy ou hospedar versão fixada internamente.
Serviço de e-mail do Supabase	Confirmação e recuperação de contas.	Configurar SMTP corporativo, remetente, SPF, DKIM e DMARC.
Navegador moderno	Execução do frontend e impressão em PDF.	Homologar Edge/Chrome corporativo e política de atualização.

3. Segurança e controle de acesso

3.1 Identidade

O fluxo atual aceita exclusivamente endereços terminados em `@metalsider.com.br` . Um gatilho de banco valida o domínio. Ao solicitar acesso, o registro de autenticação é associado a um usuário de negócio em `public.usuarios` , inicialmente com perfil-base `CLIENTE` e status `PENDENTE` . O acesso funcional depende de confirmação do e-mail, ativação administrativa e concessão de permissões.

3.2 Autorização

A autorização combina perfis e exceções individuais:

- `perfis` define papéis organizacionais.
- `permissoes` contém capacidades granulares por módulo.
- `perfil_permissoes` associa capacidades aos perfis.
- `usuario_perfis` associa usuários aos perfis.
- `usuario_permissoes` permite concessão ou negação individual.

O frontend oculta funções sem permissão, mas a proteção efetiva está no banco, por Row Level Security (RLS), grants e funções `security definer` . Ocultar um botão não é considerado controle de segurança.

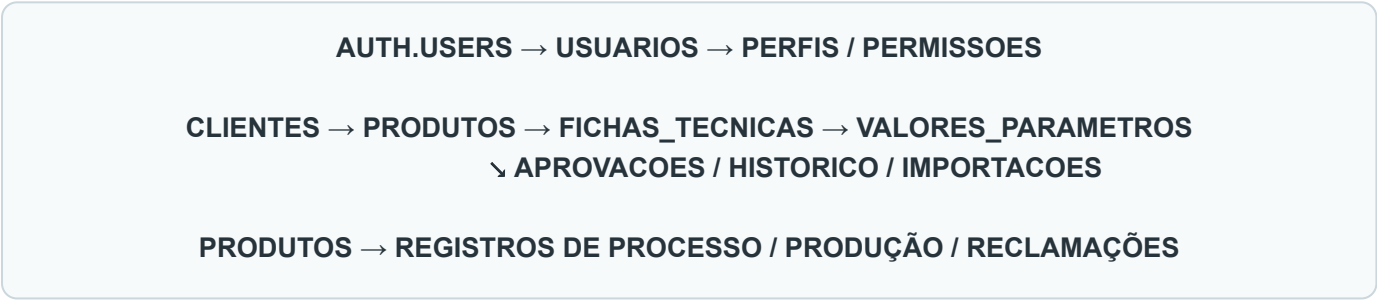
3.3 Credenciais

Regra obrigatória: a chave `service_role` não pode existir no frontend, repositório público, navegador ou estação do usuário. Ela deve permanecer somente nas Edge Functions/segredos do Supabase. A chave pública do frontend é identificadora, não substitui RLS.

3.4 Recomendações para homologação de segurança

- Decidir entre autenticação atual por senha e SSO corporativo via provedor compatível com OIDC/SAML.
- Aplicar MFA aos perfis administrativos e avaliar MFA para demais grupos.
- Definir política de sessão, expiração, bloqueio, desligamento e revisão periódica de acessos.
- Revisar todas as policies RLS e funções `security definer` antes da produção.
- Habilitar logs de autenticação, banco e funções com retenção aprovada.
- Executar teste de segurança focado em IDOR, elevação de privilégio, upload e injeção.

4. Modelo de dados



4.1 Entidades centrais

Grupo	Entidades principais	Responsabilidade
Identidade	<code>auth.users</code> , <code>usuarios</code> , <code>perfis</code> , <code>permissoes</code>	Identidade, situação e autorização.
Cadastros mestres	<code>clientes</code> , <code>produtos</code> , <code>familias_produto</code>	Dados comerciais e técnicos básicos.
Fichas	<code>fichas_tecnicas</code> , <code>grupos_parametros</code> , <code>parametros</code> , <code>valores_parametros</code>	Documentos técnicos parametrizados.
Revisão e aprovação	<code>historico_fichas</code> , <code>aprovacoes_ficha</code>	Rastreabilidade, decisão e vigência.
Importação	<code>templates_importacao_ficha</code> , <code>importacoes_ficha</code> , <code>validacoes_importacao_ficha</code> , <code>auditoria_importacao_ficha</code>	Entrada e validação de PDFs.
Produção	<code>registros_producao_moldes</code> , <code>paradas_producao_moldes</code> , <code>linhas_maquinas_producao</code> , <code>categorias_parada_producao</code>	Produção, perdas e disponibilidade.
Qualidade	<code>reclamacoes_cliente</code> , <code>anexos</code> , comentários e ações	Tratamento de ocorrências e plano de ação.

4.2 Estratégia de revisão

Cada revisão é uma nova linha em `fichas_tecnicas`. A origem é mantida por `revisao_origem_id`. A revisão anterior não é sobrescrita. A interface compara os valores da revisão nova com a origem e destaca alterações em vermelho. A publicação de uma revisão obedece ao fluxo de aprovação e vigência.

5. Fluxos críticos

5.1 Solicitação e liberação de acesso

- Usuário informa nome, e-mail corporativo e senha.
- Supabase Auth cria a identidade e envia confirmação.
- Gatilho cria `public.usuarios` com status `PENDENTE`.
- Usuário confirma o endereço de e-mail.
- Administrador seleciona perfil e permissões e ativa a conta.
- Login cria sessão; páginas validam sessão, usuário ativo e permissões.

5.2 Ficha técnica

- Engenharia cria ou importa uma ficha em rascunho.
- Parâmetros são preenchidos e validados por tipo e faixa.
- A ficha é enviada para aprovação.
- Engenharia e Produção decidem conforme a etapa configurada.
- Aprovada, a revisão passa a ser vigente; a anterior permanece histórica.

5.3 Importação de PDF

1. PDF é armazenado em bucket privado.
2. Template orienta o mapeamento dos campos.
3. Dados extraídos são conferidos e ajustados por usuário autorizado.
4. Validação gera ficha e eventos de auditoria.

6. Ambientes, implantação e mudanças

6.1 Situação atual

- Repositório local com frontend, documentação, testes, Edge Function e migrations.
- Projeto Supabase remoto vinculado ao identificador `ovtvxzedb1hfqzucidya`.
- Migrations versionadas em `supabase/migrations`.
- Não foi identificado neste repositório um pipeline corporativo completo de CI/CD.
- A hospedagem definitiva do frontend deve ser definida pelo TI.

6.2 Topologia recomendada

Ambiente	Finalidade	Dados	Deploy
Desenvolvimento	Construção e testes locais.	Sintéticos; sem dados pessoais reais.	Manual/local.
Homologação	Testes integrados e aceite.	Mascarados ou sintéticos.	Pipeline após revisão.
Produção	Operação corporativa.	Reais e controlados.	Pipeline aprovado, com evidência e rollback.

6.3 Pipeline sugerido

1. Pull request com revisão técnica e funcional.
2. Verificação de sintaxe JavaScript, testes e `git diff --check`.
3. Validação de migrations em banco de homologação restaurável.
4. Análise de segurança e de alteração de dados.
5. Deploy do frontend com versão imutável.
6. Aplicação de migrations pelo pipeline, nunca pelo navegador.
7. Smoke test, monitoramento e registro da mudança.

7. Integrações corporativas a definir

Integração	Uso potencial	Informações necessárias
Microsoft Entra ID / IdP	SSO, MFA, grupos e desligamento automático.	Tenant, protocolo, claims, grupos e política de convidados.
ERP	Sincronizar clientes, produtos, códigos e situação.	Sistema de origem, API, chaves, frequência, proprietário e regra de conflito.
MES / apontamento	Receber produção, máquina, turno e paradas.	Eventos, granularidade, latência, identificadores e retenção.
Qualidade / laboratório	Importar resultados e vincular especificações.	Formato, unidade, rastreabilidade e validação.
SMTP corporativo	Confirmação, recuperação e notificações.	Relay, porta, TLS, remetente e limites.
BI	Indicadores e painéis gerenciais.	Views autorizadas, anonimização, refresh e ferramenta.

Princípio recomendado: definir fonte oficial para cada cadastro. Caso o ERP seja mestre de clientes e produtos, o LIDUTEC+ deve consumir esses dados e limitar alterações locais aos campos complementares.

8. Operação, monitoramento e continuidade

8.1 Monitoramento mínimo

- Disponibilidade do frontend, Auth, REST, banco, Storage e Edge Functions.
- Taxa de erros HTTP 4xx/5xx, falhas de login e erros de RPC.
- Latência de consultas, conexões, armazenamento e crescimento das tabelas.
- Falhas de envio de e-mail e entregabilidade.
- Eventos administrativos: ativação, mudança de perfil e alteração de permissões.

8.2 Backup e recuperação

- Definir RPO e RTO com Engenharia, Produção, Qualidade e TI.
- Confirmar plano de backup PostgreSQL e recuperação pontual do contrato Supabase.
- Definir backup/replicação dos objetos no Storage.
- Executar e evidenciar testes periódicos de restauração.
- Versionar migrations e preservar artefatos de cada release.

8.3 Dados pessoais e LGPD

A aplicação armazena nome e e-mail de usuários e pode armazenar contatos de clientes. O TI e as áreas responsáveis devem definir finalidade, base legal, retenção, acesso, atendimento a titulares e descarte. Logs e backups também devem respeitar a política corporativa de retenção.

9. Qualidade e testes

Há testes puros para regras de turno e indicadores em `tests/turnos.test.cjs`. As verificações atuais incluem sintaxe JavaScript e consistência de diff. Para homologação corporativa, recomenda-se ampliar para:

- Testes unitários das regras de ficha, revisão, aprovação e produção.
- Testes de integração contra Supabase de homologação.
- Testes ponta a ponta de login, permissões e fluxos críticos.
- Testes de RLS com perfis permitidos e negados.
- Testes de carga para listas, históricos, gráficos e uploads.
- Validação de acessibilidade, navegadores e resolução de chão de fábrica.

10. Riscos e pontos de atenção

Risco	Impacto	Tratamento sugerido
Frontend sem pipeline corporativo formal	Mudanças manuais e divergência entre versões.	Implantar Git, PR, CI/CD e versionamento de releases.
Um único backend remoto em uso	Teste pode afetar operação.	Separar projetos Supabase por ambiente.
Dependência de CDN público	Bloqueio de rede ou alteração externa.	Fixar versão e avaliar hospedagem interna do artefato.
Autenticação por senha sem SSO definido	Gestão duplicada de identidade.	Integrar ao IdP corporativo e aplicar MFA.
Upload e URLs externas	Conteúdo indevido, indisponível ou malicioso.	Allowlist, validação de MIME, antivírus e storage privado.
Testes automatizados ainda limitados	Regressões em fluxos industriais.	Criar suíte unitária, integração e E2E.
Cadastros duplicados entre sistemas	Inconsistência de cliente/produto.	Definir sistema mestre e integração idempotente.

11. Checklist para início da integração

Frente	Decisões e evidências necessárias	Responsável sugerido
Patrocínio	Process owner, escopo, usuários, criticidade e SLA.	Negócio + TI
Arquitetura	Aprovação do Supabase, região, conectividade e hospedagem.	Arquitetura TI
Identidade	SSO/MFA, grupos, ciclo de vida e conta de serviço.	IAM/Segurança
Dados	Sistemas mestres, classificação, retenção e LGPD.	Dados + DPO + Negócio
Segurança	Threat model, RLS, pentest, segredos e logs.	Segurança TI
Infraestrutura	DNS, TLS, proxy, firewall, SMTP e observabilidade.	Infra/Cloud
Desenvolvimento	Repositório oficial, branches, code review, CI/CD e releases.	DevOps/Desenvolvimento
Continuidade	RPO, RTO, backup e teste de restauração.	Infra + Negócio
Homologação	Casos de teste, massa, aceite e plano de implantação.	QA + Usuários-chave
Sustentação	Catálogo, chamados, níveis de suporte e runbook.	Service Desk + Produto

12. Proposta de fases

1. **Assessment:** workshop técnico, inventário, classificação da informação e aprovação da arquitetura.
2. **Fundação:** repositório oficial, ambientes, SSO/SMTP, segredos, DNS e pipeline.
3. **Hardening:** revisão de RLS, logs, testes, backup e segurança.
4. **Integração:** conectar ERP/MES/BI conforme prioridade e fonte mestra.
5. **Homologação:** testes funcionais, carga, segurança, treinamento e aceite.
6. **Produção:** implantação controlada, hypercare, indicadores e sustentação.

13. Inventário técnico do repositório

Caminho	Conteúdo
pages/	Telas da aplicação organizadas por módulo.
assets/js/	Regras do frontend, autenticação, consultas e renderização.
assets/css/	Design system e estilos dos módulos.
supabase/migrations/	Evolução versionada do banco, policies, funções e permissões.
supabase/functions/	Edge Functions; atualmente inclui gestão administrativa de usuários.
tests/	Testes automatizados disponíveis.
docs/	Documentação funcional, técnica, DER e módulos.
dev-server.cjs	Servidor HTTP para execução local.

14. Comandos operacionais de referência

Desenvolvimento local

`node dev-server.cjs` — disponibiliza a aplicação em `http://127.0.0.1:8080/`.

Testes atuais

`node tests/turnos.test.cjs`

Migrations

`npx supabase migration list --linked` — consulta o estado das migrations.

`npx supabase db push --linked` — aplica migrations pendentes. Em ambiente corporativo, deve ser executado somente pelo pipeline e após aprovação.

15. Critérios sugeridos para entrada em produção

- Arquitetura e fornecedor aprovados pelo TI.
- Ambientes separados e pipeline auditável.
- SSO/SMTP e ciclo de vida de usuários homologados.
- Revisão de segurança e RLS concluída sem achados críticos.
- Backup e restauração testados.
- Monitoramento, alertas e runbook disponíveis.
- Testes dos fluxos críticos aprovados pelos usuários-chave.
- Plano de implantação, rollback, treinamento e suporte aprovado.

16. Glossário

Termo	Definição
RLS	Row Level Security; políticas PostgreSQL que controlam acesso por linha.
RPC	Função de banco invocada remotamente para executar uma operação transacional.
SSO	Single Sign-On; autenticação centralizada pelo provedor corporativo.
IdP	Identity Provider, como Microsoft Entra ID.
RPO	Perda máxima aceitável de dados em caso de incidente.
RTO	Tempo máximo aceitável para restauração do serviço.
Migration	Script versionado que altera de forma controlada o esquema ou regras do banco.
Edge Function	Função server-side executada fora do navegador para operações privilegiadas.

Documento elaborado a partir do estado do repositório LIDUTEC+ em 27/07/2026. Antes da apresentação formal, recomenda-se incluir nomes dos responsáveis, classificação oficial da informação, diagrama de rede corporativo e decisões do assessment com o TI.